LogosFuzz

빌드 구조와 API 제약 분석 기반 퍼징 하네스 자동 생성 보안 테스트 시스템

김민주 · 송서원 · 임세은 · 황다연 (서울여자대학교) | 팀 FuzzingCandy

3,080
S-CORE C++ API 추출
기존 0개 → 682개 로직 그룹

181→216
S-CORE 커버리지
동일 조건, 300초 실행

2 / 2
LLM 하네스 빌드 성공
DLT·S-CORE, 자가치유 1회

1,182
테스트 통과
단위·통합 테스트

01 배경과 목표

왜 필요한가

- **공급망 위험**: 라이브러리 하나의 결함이 SW 전체로 확산 (Heartbleed, BadAlloc, Redis)
- **높은 진입장벽**: OSS-Fuzz가 1,000개 프로젝트에서 10,000건+ 발견했지만 수작업 하네스 필요
- **규제**: 자동차·SDV는 UN R155(CSMS) 준수 의무

기존 방식의 한계

- **수작업**: 프로젝트당 수 시간과 전문지식
- **구조 복원 실패**: score/json 106개 파일에서 API 0개 추출
- **환경 의존 오류**: 하드웨어·외부 함수 부재로 링크 실패와 가짜 크래시

개발 목표

"프로필 1개 설정, 명령어 한 줄로 지식 추출부터 크래시 판별까지"

```
$ logosfuzz run --profile
  targets/libsndfile.json --budget 600
```

02 5단계 자동화 파이프라인

EXT 지식 추출
Bazel query, AST·주석에서 API 제약 KB 생성

▸ **SCH** 스케줄링
연관 API 로직 그룹화, 시너지 점수와 시간 배분

▸ **GEN** 하네스 생성
LLM 하네스 생성, 오류 분류 자가치유

▸ **EXE** 퍼징 실행
Docker 격리 libFuzzer, ASan/UBSan

▸ **ANA** 크래시 분석
중복 제거, 규칙 판별, 리포트

오탐 역피드백 ANA 원인 분석 → KB 변경안(diff) → 사람 승인 → KB 반영 → 해당 그룹 하네스 재생성

03 핵심 기술

다중 소스 지식 추출

AST, 주석, 분기문에서 NULL 검사·버퍼-길이 쌍·값 범위·해제 책임을 추출해 신뢰도와 함께 하네스 프롬프트에 주입

빌드 자가치유

컴파일·링커 오류(미정의 심볼, 중복 정의, 라이브러리 누락)를 분류해 LLM이 수정, 미정의 HAL 함수는 weak 스텁 자동 생성

10→85%
크래시 판별 정확도
규칙 판별 + 신뢰도 0.8 미만은 증거 주입 LLM 판별 (dlt-daemon 크래시 20건 기준)

04 대상별 검증 결과

Eclipse S-CORE
`BAZEL · 자동차`
216
커버리지 (기존 181)
API 3,080 · 그룹 682

COVESA DLT
`COMPILE_COMMANDS · 자동차`
373K/s
API 914개
제약조건 보유 80.6%

libsndfile 1.2.2
`CMAKE · 범용 C`
6건
UBSan 정수 오버플로우
고유 6건 (검토 대기)

임베디드 HAL
`PREBUILT · 임베디드`
86.4%
라인 커버리지, 브랜치 70.0%
HAL 스텁 후 힙 OOB 탐지

범용 프로필: 대상마다 JSON 프로필 하나만 작성하면 빌드 방식이 달라도 같은 명령어로 실행 · ※ libsndfile·임베디드는 수동 하네스, S-CORE·DLT는 LLM 생성 하네스 실측

05 기존 도구 비교 · 보안 설계

기존 도구 비교

비교 항목	Locus	Prome Fuzz	OSS-Fuzz-Gen	lib Erator	Logos Fuzz
LLM 하네스 생성	△	○	○	×	○
API 문서 활용(RAG)	×	○	△	×	○
API 호출 순서 추론	△	△	×	○	○
빌드 오류 자동 수정	×	×	○	×	○
Coverage 최적화	○	○	○	△	○
크래시 정탐/오탐 분류	×	○	×	×	○
Bazel·임베디드 대응	×	×	×	×	○

○ 지원 △ 일부 지원 × 미지원

보안약점 예방 설계

신뢰 경계 분리
LLM 코드·퍼징 입력은 격리 컨테이너에서만 실행

명령 문자열 미사용
shell=True, eval/exec 0건

사람 승인 게이트
KB 변경·취약점 공개는 HITL 승인, 감사 로그

비밀정보 보호
API 키는 환경변수, 리포트 esc() 처리

47→29
Bandit 검출
High/Medium 0

100%
조치 대상 18건
모두 조치

0건
의존성 취약점
비밀정보 노출

06 기대효과 · 향후 계획

기대효과

- **하네스 작성 자동화**: 프로필 1회 작성으로 수작업 대체
- **탐지 범위 확대**: 하드웨어 없이 임베디드 코드 탐색
- **공급망 검증**: 도입 전 보안 검증, UN R155 증거 축적

향후 계획

- **기술 고도화**: ASan 크래시 위치 복원, 누락 로직 그룹 보완
- **검증 자동화**: GitHub Actions 연동 CI 보안 검증
- **범위 확대**: 바이너리 대상 퍼징, 다양한 CPU 아키텍처

github.com/sesezz/LogosFuzz

대상 Eclipse S-CORE · DLT daemon · libsndfile · 임베디드 HAL
스택 Python · libclang · Bazel · libFuzzer · Docker